Statement of Applicability

LLM API Security and the MATRIS Method™

Prepared by	Community Tech Aid, a service of eBiz Market, LLC (communitytechaid.ai)
Author	Kelly Guzman, GRC & Compliance Analyst
Target scope	LLM API integrations, chatbots, and tool-using agents
Testing framework	The MATRIS Method™, mapped to the OWASP Top 10 for LLM Applications 2026
Document version	2.0
Effective date	2026-10-27
Supersedes	Version 1.0 (mapped to OWASP Top 10 for LLMs 2023, v1.1)

1. Purpose and Scope

This Statement of Applicability (SoA) defines which security risk categories Community Tech Aid tests when evaluating an LLM API integration, which categories are excluded, and why.

Organizations that add AI through an external or internal model API move part of their attack surface from the network perimeter to the language layer: instruction manipulation, data leakage through conversation, and model output that triggers actions. This document states how the MATRIS Method™, a no-code AI red-teaming framework, identifies and validates those risks.

In scope: the interaction layer between the user (or threat actor), the application's API endpoint, the hidden context the application supplies to the model, any retrieval or tool layer the model can reach, and the client interface that renders model output.

Out of scope: the model provider's training pipeline, model weights, and provider-hosted infrastructure. These are inherited controls and are addressed through vendor assessment, not testing.

2. Methodology: The MATRIS Method™

The MATRIS Method™ is an outside-in (black-box) assessment. It tests the deployed application the same way a user or attacker reaches it, through its prompts, uploads, and API calls, without source code, backend access, or model weights.

Testers work through structured, visual test cases rather than terminal tooling, which allows small businesses and non-technical product owners to see each test, its result, and its evidence. Testing is delivered through the MATRIS Method™ Red-Team Console (redteam.communitytechaid.ai).

Because the method is black-box, it validates **observable behavior**. Where a risk can only be confirmed from inside the system, this SoA marks it as *Documentation Review* or *Inherited* rather than claiming test coverage the method cannot provide.

The MATRIS Method™ Red-Team Console is listed in the OWASP GenAI Security Project Solutions Directory under AI Red Teaming.

3. Applicability Key

Status	Meaning
Applicable	Tested in every engagement.
Conditional	Tested when the client system includes the relevant feature (tools, retrieval, file upload). Recorded as Not Present when absent.
Documentation Review	Not testable from outside. Assessed through client-supplied inventory and vendor documentation.
Inherited	Owned by the model provider. Excluded from testing; noted as a vendor-risk item.

4. Control Applicability and OWASP Mapping

OWASP 2026 Category	Status	MATRIS Method™ Validation Approach
LLM01:2026 Prompt Injection	Applicable	Direct injection through user input (role-play, persona adoption, delimiter and formatting abuse, multi-turn escalation). Indirect injection through any content the system ingests on the user's behalf (documents, URLs, pasted text). Cross-modal payloads where image or file upload exists.
LLM02:2026 Sensitive Information Disclosure	Applicable	Targeted probing for PII, credentials, internal business data, and other users' data. Tests whether the application authorizes data *before* retrieval rather than filtering after generation.
LLM03:2026 Excessive Agency	Conditional (tools or actions present)	Action-boundary testing: attempts to trigger tool calls, data changes, messages, or purchases outside the user's intended task. Verifies human-in-the-loop approval on irreversible actions and that the approval shows the actual action.
LLM04:2026 Supply Chain	Documentation Review	Review of the client's model, plugin, connector, and vendor inventory (AI Bill of Materials if available). Third-party components are not tested directly.
LLM05:2026 Data and Model Poisoning	Inherited	Excluded from testing. Pretraining and provider fine-tuning belong to the model provider. If the client fine-tunes its own model, provenance records are reviewed under LLM04.
LLM06:2026 Unbounded Consumption	Applicable	Tests for server-side limits on output length, context size, request rate, and spend. Checks whether user input can raise token limits. Stress testing runs only within a cost ceiling agreed in writing before testing begins.

OWASP 2026 Category	Status	MATRIS Method™ Validation Approach
LLM07:2026 Misinformation	Applicable	Induces fabricated facts, citations, and flawed reasoning. Verifies that the application grounds answers, discloses AI involvement, and requires verification before output drives a decision or action.
LLM08:2026 Hidden Context Exposure	Applicable	Attempts to extract the system prompt, tool schemas, configuration values, and developer instructions. Any secret found in model context is reported as a finding regardless of severity of the prompt itself.
LLM09:2026 Vector and Embedding Weaknesses	Conditional (retrieval or memory present)	Cross-user and cross-tenant retrieval testing. Where user content is written to an index or memory, tests whether planted instructions persist into later sessions.
LLM10:2026 Improper Output Handling	Applicable (client-side sinks)	Tests the rendering interface for script execution, injected links, and auto-loaded external resources (for example, markdown images used as a data-exfiltration channel). Server-side sinks such as database queries or shell commands are tested only where their effect is observable from outside.

Agentic systems: where the client deploys autonomous agents with persistent memory or multi-step tool chains, findings are cross-referenced to the OWASP Top 10 for Agentic Applications (December 2025) in addition to the categories above.

Test evidence to date is recorded in the MATRIS Method™ OWASP coverage table. That table still uses 2025 numbering; it is being renumbered to the 2026 edition.

5. Exclusions and Justification

Exclusion	Justification
Model weights and model extraction of the base model	Owned and protected by the model provider; not reachable at the application layer.
Provider training data and pretraining poisoning (LLM05)	No client control or visibility; assessed as vendor risk.
Source code review and backend configuration	Outside the black-box method. Can be added as a separate engagement.
Denial of service against provider infrastructure	Not authorized and not part of the method. Consumption testing targets the client's own limits only.

6. Rules of Engagement

1. Testing begins only after written authorization from the system owner, naming the systems, accounts, and test window.
2. Testing uses dedicated test accounts and synthetic data. No real customer records are entered or extracted.

3. Consumption testing stays within a spend ceiling agreed before the engagement.
4. Testing complies with the model provider's usage policies.
5. Any live exposure of credentials or personal data found during testing is reported to the client immediately, not held for the final report.
6. Findings, evidence, and transcripts are confidential to the client.

7. Governance, Risk, and Compliance (GRC) Output

Every finding becomes a documented, trackable record. Each record contains:

Field	Content
Finding ID	Unique identifier, for example `MATRIS-2026-001`
OWASP category	LLM01:2026 through LLM10:2026
Severity	Critical, High, Medium, or Low (see below)
Evidence	Dated prompt and response transcript, plus screenshots
Business impact	Plain-language description of what an attacker gains
Recommended control	Specific fix the client or its vendor can implement
Owner and due date	Assigned by the client
Retest result	Open, Remediated, or Risk Accepted (with the approver named)

Severity scale

Severity	Definition
Critical	Exposes credentials or other users' data, or triggers an unauthorized irreversible action.
High	Reliably bypasses a stated safety or business rule, or exposes hidden context containing sensitive configuration.
Medium	Bypass requires significant effort or produces limited impact; misinformation in a decision path.
Low	Policy or tone deviation with no data or action impact.

Framework alignment

Engagement phase	NIST AI RMF function
Scoping, authorization, and system inventory	GOVERN, MAP
Testing and evidence collection	MEASURE
Remediation, risk acceptance, and retest	MANAGE

Findings can additionally be mapped to NIST AI 600-1 (Generative AI Profile) and ISO/IEC 42001 controls when the client requires evidence for those frameworks.

8. Review Cycle

This SoA is reviewed when OWASP publishes a new edition of the LLM Top 10, when the MATRIS Method™ adds a test category, or at least annually.

References

- OWASP GenAI Security Project, *OWASP Top 10 for LLM Applications 2026*: https://genai.owasp.org/resource/owasp-genai-llm-top-10-2026/
- OWASP GenAI Security Project, *OWASP Top 10 for Agentic Applications* (December 2025)
- NIST, *AI Risk Management Framework (AI RMF 1.0)*: https://www.nist.gov/itl/ai-risk-management-framework
- NIST AI 600-1, *Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile*
- ISO/IEC 42001:2023, *Artificial intelligence management system*

MATRIS Method™ is a trademark of eBiz Market, LLC. Community Tech Aid is an assumed business name of eBiz Market, LLC.